

MODULE 4: HOW TO HUNT FOR BUGS

Bug Bounty Methodology, Vulnerabilities & Tools

HACKER_MODE: ENABLED

MODULE ROADMAP

From understanding program scopes to mastering reconnaissance and identifying modern web vulnerabilities.



FOUNDATIONS

Scope & Guidelines



METHODOLOGY

7-Phase Workflow



VULNERABILITIES

XSS, IDOR, SQLi & More



TOOLKIT

Phase-wise Tools

| UNDERSTANDING SCOPE & GUIDELINES



ASSET DEFINITION

- > Always identify **In-Scope** targets
- > Verify Wildcard domains (*.target.com)
- > Note restricted Out-of-Scope assets
- > Check for specific subdirectories



RULES OF ENGAGEMENT

- > Understand **Safe Harbor** policies
- > Avoid prohibited testing (DoS/DDoS)
- > Check reward and severity ladders
- > Follow disclosure timing guidelines

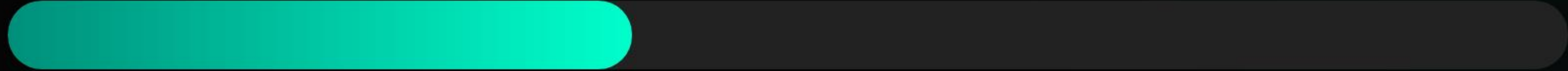
| PUBLIC VS. PRIVATE PROGRAMS

Competition Level



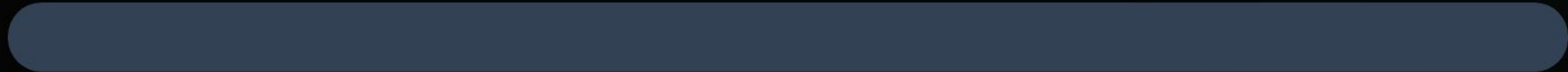
Public

Competition Level



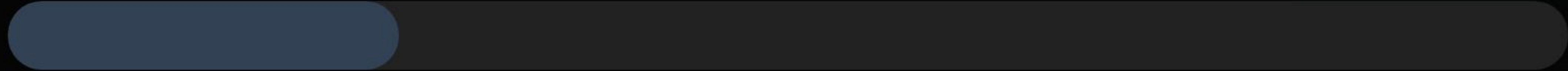
Private

Ease of Access



Public

Ease of Access



Private

VULNERABILITY DISCLOSURE (VDP)

Good for reputation; usually no monetary rewards.

PRIVATE INVITATION

Earned through high-quality reports on public programs.

| THE BUG BOUNTY LIFECYCLE



A successful hunt depends on **methodology over tools**. Document every step from the start.

PHASE 1 & 2: RECONNAISSANCE

MASTERING INFORMATION GATHERING

Goal: Discover the largest possible attack surface before competitors.

Passive Recon (OSINT)

Search archives, certificate logs, and public repos without direct interaction.

Active Recon

Live host probing, port scanning, and service version identification.

Reconnaissance output terminal

PHASE 3: ENUMERATION & MAPPING



JS ANALYSIS

Read client-side code to find hidden endpoints, API keys, and sensitive comments. Use

`LinkFinder`.



TECH STACK

Identify frameworks (React, PHP, Node) and versions using

`Wappalizer` or `nuclei`.



AUTH DISCOVERY

Find admin panels, login forms, and sign-up flows that might be vulnerable to bypass.

Pro Tip: Fuzz for parameters using `ffuf` to find unindexed functionality.

COMMON VULNERABILITY LANDSCAPE

XSS

Cross-Site Scripting
via payload injection in
inputs or URL params.

IDOR

Insecure Direct Object
Reference - accessing
data belonging to
others.

SQLI

SQL Injection -
manipulating
database queries to
extract sensitive info.

SSRF

Server-Side Request
Forgery - forcing the
server to query internal
resources.

MEETS
IDOR

| RECENT SECURITY TRENDS (2024-2025)

53%

High/Critical Severity

Percentage of scored CVEs in 2024 that were rated High or Critical.

KEY FOCUS AREAS:

- > **Broken Access Control:** Accounted for a staggering portion of 2024 breaches.
- > **API Misconfigurations:** Widespread exposure of sensitive PII.
- > **Cloud Security:** Misconfigured S3 buckets and IAM roles.
- > **JWT & GraphQL:** New era of logical bugs in modern architectures.

THE ESSENTIAL TOOLKIT

Phase	Recommended Tools	Primary Function
Reconnaissance	subfinder, amass	Subdomain discovery and OSINT gathering.
Asset Discovery	httpx, naabu	Checking for live web hosts and open ports.
Crawling	katana, gau	URL extraction and site spidering.
Scanning	nuclei, dalfox	Template-based vulnerability checks.
Manual Testing	Burp Suite	Interception, modification, and custom testing.

| THE PRO HUNTER'S CHECKLIST

- > **Define Scope:** Read the policy twice. Identify wildcard domains and exclusions.
- > **Wide Recon:** Run subdomain discovery. Use tools like `subfinder` + `dnsx`.
- > **Spidering:** Crawl the application. Collect URLs, JS files, and hidden endpoints.
- > **Deep Dive:** Analyze JavaScript for secrets, API endpoints, and logic flaws.
- > **Fuzzing:** Test all input parameters for XSS, SQLi, and SSRF.
- > **Validate Impact:** Can you escalate it? Can you prove business risk?
- > **Report:** Clear PoC, steps to reproduce, and remediation advice.

NEXT STEPS

Start hunting on beginner-friendly targets today!

LEARN

PortSwigger Academy
OWASP Top 10

PRACTICE

TryHackMe
Hack The Box

HACK

HackerOne
Bugcrowd

Questions? Contact: support@cyber-training.com

IMAGE SOURCES



<https://www.wizlynxgroup.com/news/wp-content/uploads/2025/09/wizlynx-guide-top-pentesting-tools.jpg>

Source: www.wizlynxgroup.com



https://miro.medium.com/v2/resize:fit:1400/1*_dSrfoTWqk0ySifsezdpFQ.jpeg

Source: infosecwriteups.com



https://static.vecteezy.com/system/resources/previews/075/392/954/non_2x/abstract-digital-network-connection-with-futuristic-nodes-and-lines-on-dark-blue-background-suitable-for-big-data-cybersecurity-communication-and-ai-design-vector.jpg

Source: www.vecteezy.com
